Vulnérabilité d'Affectation de Mass

Ce type de vulnérabilité apparait lorsque le développeur oublie de filtrer les donn autorisées. Un attaquant peux ainsi ajouter des champs supplémentaires dans u requête qu'il envoi au serveur. Par exemple en plus d'un username et d'un pas ord il envoi un champ isadmin=true
Si l'application est mal codé elle pourrait voir et interpréter ce champ discerna ainsi des privilèges administrateurs au compte créer
Pour voir quel paramètre injecter il faux avoir accès ou deviner le code source d l'application vulnérable. Quelques définitions pour clarifier

Mass Assignement: Une fonctionnalité d'un framework web qui permet de l automatiquement les données d'un formulaire utilisateur (ex: mail, mot de pa a un objet de donnée (comme un profil utilisateur) en une seule opération.
Elle survient lorsque l'application ne met pas en place une liste blanche pour spéci quels champs l'utilisateur a le droit de modifier, l'attaquant peu donc envoyer de champs additionnels malveillant que l'application va assigner à son profil sans vérifi

Attaquer les Application se connectant à des Services:

Pour ce chapitre on va prendre deux exemples, un avec un executable ELF (Exe able and Linkable Format) et le second avec un fichier .dll, le but étant de "disséqu ces programmes à la recherches de potentielles chaines de connexions hardcodé.

1- Commençons avec notre ELF

Qu'est ce que GDB? c'est un débogger, un outil qui permet d'exécuter des pro rammes pas à pas, de l'arrêter à des moments précis et d'inspecter son état inter (la mémoire, les variables, etc) pendant qu'il tourne
PEDA: est une extention pour GDB qui le rend beaucoup plus facile à utiliser po la sécurité informatique. Il affiche les informations importantes (comme l'état de registres du processeur et de la mémoire) de manière claire et colorié. On va dirige de trouver l'exact moment ou le programme s'apprête à se connecter à un service me une base de donnée et d'intercepter les credentials à ce moment là.

1- On charge le programme dans GDB

```
Agentpathogene@parrot ~$ gdb ./programme
```

2- On traduit le code machine binaire en langage de désassemblage (assem une représentation textuelles des instructions du processeurs. (et ici on affiche la f ction main "désassemblé")

```
gdb-peda ~$ set disassembly-flavor intel
gdb-peda ~$ disas main
```

3- On voit un call à SQLDriverConn peu ajouter un breakpoint à cette adresse puis r run qui va exécuter le programme s'arrêter à l'adresse, inspecter les registres proc seurs (petites zone mémoires ultra rapique que le processeur utilise pour stocke temporairement des données) quand un programme appelle une fonction il plac souvent les argument (données nécessaires à cette fonction) dans ces registres, ma revelant ainsi la chaine de connexion SQL

```
gdb-peda ~$ b *0x555555160
gdb-peda ~$ run
```

2- Examen d'un fichier DLL

Un fichier dll basé sur la technologie .NET n'est pas directement compilé en langa machine comme un ELF il est compilé en un langage intermédiaire (IL)